Objective 2.2 — Apply enumeration techniques

Enumeration is a funnel: find what is **alive**, then what is **listening**, then what is **exposed** on DNS and the web, then **who and what you can reach**, then **wireless** — and finally you **chain it** into an attack path. This is the confusable-heavy domain, so a dedicated cram plus ports/flags/codes references sit alongside the notes. Domain 2.0 = 21%% of the exam.

1 · The enumeration funnel

Each stage narrows the picture and feeds the next; the last stage chains findings into an attack path.

P1 · Find hosts & OS who is alive, running what	2 techniques
P2 · Find services & protocols what is listening	2 techniques
P3 · Map DNS & the web what is exposed online	5 techniques
P4 · Enumerate identity & access who / what can I reach	5 techniques
P5 · Go wireless the RF attack surface	1 technique
P6 · Chain it — attack paths connect findings to the goal	1 technique

2 · Concept cards

All 16 sub-objective techniques — what it is, high-yield facts, tools, exam tell. Grouped by funnel stage.

P1 · FIND HOSTS & OS

Host discovery P1

`2.2 > Host discovery`

WHAT IT IS Find which IP addresses have live systems before deeper scanning.

- `-sn` = ping sweep — discovery only, **no port scan**
- ICMP is often blocked; a silent host may still be alive
- Alternates: TCP SYN ping `-PS`, TCP ACK ping `-PA` (bypasses stateful firewalls), UDP ping `-PU`
- **ARP** is the most reliable on a LAN — it can't be blocked at Layer 2
- Internal: `arp -a`, `net view`, DHCP logs

TOOLS `nmap -sn / -PS / -PA / -PU, arp -a, net view`
EXAM TELL "ICMP blocked, find live hosts" -> `-PS`/`-PA`. Do **not** confuse `-sn` (sweep) with `-Pn` (skip discovery).

OS fingerprinting P1

`2.2 > OS fingerprinting`

WHAT IT IS Identify the remote OS from TCP/IP-stack quirks.

- `nmap -O` = **active** (crafted probes); `-A` = OS + version + scripts + traceroute
- **Passive** = p0f / Wireshark reading TTL, TCP window size — no packets sent
- TTL tell: **Windows 128, Linux/Unix 64**
- `--osscan-guess` forces a best guess when ambiguous

TOOLS `nmap -O / -A, p0f, Wireshark`
EXAM TELL "identify OS without sending probes" -> passive (p0f); TTL 128=Win / 64=Linux is a classic.

P2 · FIND SERVICES & PROTOCOLS

Service discovery P2

2.2 > Service discovery

WHAT IT IS Determine which application and version listens on each open port.

- `-sV` = version detection (probes; beats banner grabbing, which can be faked)
- `--version-intensity 0-9` tunes depth
- Banners via `nc` / `telnet` / `curl`
- **NSE** goes deeper: `http-server-header`, `smb-os-discovery`

TOOLS `nmap -sV, nc, NSE scripts`
EXAM TELL "identify the running service version" -> `-sV`; more reliable than banner grabbing.

Protocol enumeration P2

2.2 > Protocol enumeration

WHAT IT IS Identify active protocols and pull config/intel; flag insecure implementations.

- **SNMP** community strings: `public` (read) / `private` (read-write); v1/v2c are **cleartext** — `snmpwalk` dumps routing/ARP/processes/users
- **SMBv1** = EternalBlue / MS17-010 — a critical finding
- UDP closed -> ICMP Port Unreachable; no reply = **open|filtered**
- **LDAP null bind** = unauthenticated query on misconfigured servers

TOOLS `snmpwalk, nmap NSE (snmp-info, smb-os-discovery), enum4linux`
EXAM TELL SNMP `public/private` + `snmpwalk`; **SMBv1** = critical; `open|filtered` is UDP-specific.

P3 · MAP DNS & THE WEB

DNS enumeration P3

2.2 > DNS enumeration

WHAT IT IS Query DNS to map subdomains, mail, and infrastructure.

- **AXFR zone transfer** = highest-value misconfig — whole zone in one query: `dig axfr @ns domain`
- Records: A/AAAA, MX (mail), NS, CNAME, PTR (reverse), TXT (SPF/DKIM), SOA, **SRV** (hidden services)
- Blocked AXFR -> brute subdomains: dnsrecon, dnsenum, Amass, `gobuster dns`
- **Dangling CNAME** -> subdomain-takeover risk

TOOLS `dig, nslookup, Amass, DNSdumpster, dnsrecon`
EXAM TELL "server allows zone transfers" -> `dig axfr`; SRV reveals hidden services; PTR = reverse lookup.

Directory enumeration P3

2.2 > Directory enumeration

WHAT IT IS Brute-force hidden web paths and files from wordlists.

- HTTP codes: **200** exists, **301/302** redirect, **403 exists-but-restricted (note it!)**, **404** gone, **500** error
- Tools: Gobuster, DirBuster, Dirsearch, Wfuzz, ffuf, Burp Intruder
- High-value: `/admin`, `/backup`, `/config`, `/.git`, `/phpinfo.php`
- **CeWL** builds a custom wordlist from the site; check **robots.txt** first
- Directory-listing misconfig exposes all files in a folder

TOOLS `Gobuster, DirBuster, Wfuzz, ffuf`
EXAM TELL **403 = directory EXISTS but restricted** (not "gone"). "brute force paths" -> this (vs crawling).

Web crawling P3

2.2 > Web crawling

WHAT IT IS Follow links to map the app's full page/endpoint/input structure.

- Burp Spider / OWASP ZAP build a site map
- **AJAX spider needed for SPAs** (React/Angular/Vue load content via JS)
- vs directory enum: crawling follows **existing links**; dir enum brute-forces **unlinked** paths — use both
- Scope control: don't crawl third-party sites (RoE)

TOOLS `Burp Suite, OWASP ZAP, Scrapy, wget/HTTrack`
EXAM TELL JavaScript-heavy/SPA -> **AJAX spider** (ZAP). "follow links" = crawling; "brute paths" = dir enum.

WAF enumeration + origin address P3

`2.2 > WAF enumeration`

WHAT IT IS Detect and fingerprint the WAF, then find the true origin IP behind it.

- **WafW00f** detects/fingerprints; headers CF-RAY (Cloudflare), X-Sucuri-ID
- **Origin IP = crown jewel** — a direct connection bypasses ALL WAF filtering
- Find it via: DNS history (SecurityTrails/ViewDNS), CT logs (crt.sh), non-proxied subdomains (mail/ftp/dev), SPF records, Shodan/Censys by cert, leaked X-Real-IP / email headers

TOOLS `WafW00f, crt.sh, Shodan, nmap http-waf-detect`
EXAM TELL "real IP behind the WAF" -> **origin address** via DNS history / CT logs / Shodan.

Manual enumeration P3

`2.2 > Manual enumeration (robots/sitemap/plugins)`

WHAT IT IS Mine files the org published for legitimate purposes.

- **robots.txt is NOT an access control** — `Disallow` maps sensitive dirs to browse directly
- `sitemap.xml` = full URL inventory incl. hidden pages; old `lastmod` = unmaintained
- Plugins via HTML source (`/wp-content/plugins/`), **WPScan** (`--enumerate p`), Nikto -> NVD/Exploit-DB

TOOLS `browser, WPScan, Nikto`
EXAM TELL robots.txt `Disallow` = target list, not protection; **WPScan** = WordPress plugins.

P4 · ENUMERATE IDENTITY & ACCESS

Share enumeration P4

`2.2 > Share enumeration`

WHAT IT IS Find accessible SMB shares, their permissions, and sensitive contents.

- SMB ports **445 (modern) / 139 (NetBIOS legacy)**
- Admin shares: C$, ADMIN$, **IPC$**, SYSVOL
- **Null session** = unauthenticated connect to IPC$
- **SYSVOL** may hold **GPP passwords** (the AES key is public -> decryptable)
- SMBMap shows R / W / No-Access; CrackMapExec sweeps a subnet

TOOLS `SMBMap, CrackMapExec, smbclient, enum4linux`
EXAM TELL null session -> IPC$; SYSVOL -> GPP passwords; SMBMap shows permission levels.

Local user enumeration P4

`2.2 > Local user enumeration`

WHAT IT IS Discover accounts, groups, and privileges for escalation/lateral planning.

- **/etc/passwd** world-readable (no passwords); **/etc/shadow** root-only (hashes)
- Linux root = **UID 0**
- Windows: `Get-LocalUser`, `net user`, `net localgroup administrators`, `whoami /priv`
- High-value groups: Administrators, **Backup Operators**, Remote Desktop Users
- Stale + service accounts are soft targets

TOOLS `Get-LocalUser, net user, PowerView Get-NetUser`
EXAM TELL `/etc/passwd` (world-readable, no pw) vs `/etc/shadow` (root-only, hashes); UID 0 = root.

Email account enumeration P4

`2.2 > Email account enumeration`

WHAT IT IS Build a list of valid organizational email addresses.

- **SMTP VRFY** verifies one address; **EXPN** expands a mailing-list alias; RCPT TO is the fallback
- theHarvester **discovers**; Hunter.io **verifies** + reveals the naming format
- LinkedIn names + known format -> generate hundreds; HIBP for breach exposure
- Output feeds phishing / spearphishing / credential stuffing

TOOLS `theHarvester, Hunter.io, SMTP VRFY/EXPN, SpiderFoot`
EXAM TELL **VRFY** = verify one; **EXPN** = expand a list; theHarvester=discover vs Hunter.io=verify.

Permission enumeration P4

2.2 > Permission enumeration

WHAT IT IS Find misconfigured or over-permissive access controls.

- Linux **SUID** (`find / -perm -4000`) runs as owner (often root) = critical escalation; `getfacl`
- Windows `Get-Acl` / `icacls`; unquoted service path
- AD ACLs via PowerView `Get-ObjectAcl` — look for **GenericAll / WriteDACL / WriteOwner**
- **BloodHound** graphs the escalation path; cloud IAM `*` wildcards (Pacu)

TOOLS `BloodHound, PowerView Get-ObjectAcl, SMBMap, Pacu`
EXAM TELL SUID = runs as owner (escalation); GenericAll on Domain Admins = path; BloodHound finds it.

Secrets enumeration P4

2.2 > Secrets enumeration (keys/passwords/API/tokens)

WHAT IT IS Hunt passwords, API keys, cloud keys, and session tokens where they don't belong.

- Cloud keys: `~/.aws/credentials`, `.env`, **169.254.169.254** metadata (IMDSv1) -> Pacu
- **TruffleHog / GitLeaks** scan Git **history** (deleted keys persist); Trivy scans images/FS
- Passwords: **SAM** (local hashes) vs **NTDS.dit** (all domain hashes on a DC); Mimikatz from LSASS
- Tokens: **JWT** (forge if signing secret is weak); Burp/Wireshark capture -> session hijack

TOOLS `TruffleHog, Mimikatz, Pacu, Burp Suite`
EXAM TELL 169.254.169.254 = cloud metadata keys; **SAM=local vs NTDS.dit=domain**; JWT manipulation if signing weak.

P5 · GO WIRELESS

Wireless enumeration P5

2.2 > Wireless enumeration

WHAT IT IS Identify APs, SSIDs, security, and clients around the target.

- **Kismet = passive** (monitor mode, transmits nothing)
- **Aircrack-ng suite = active**: airmon-ng (monitor) -> airodump-ng (capture handshakes) -> aireplay-ng (deauth) -> aircrack-ng (crack)
- **WiGLE.net** = crowdsourced global AP database (passive pre-engagement); InSSIDer = live local analyzer
- WEP broken; WPA2-PSK crackable offline after handshake; **WPS PIN -> Pixie Dust**; hidden SSID via probe monitoring

TOOLS `Aircrack-ng, Kismet, WiGLE.net, InSSIDer`
EXAM TELL passive detection -> **Kismet**; capture handshake -> **airodump-ng**; WPS -> Pixie Dust.

P6 · CHAIN IT — ATTACK PATHS

Attack path mapping P6

2.2 > Attack path mapping

WHAT IT IS Chain individual findings into a route from foothold to objective.

- Findings become **chains** — each step enables the next
- **BloodHound** graphs AD paths to Domain Admin (Neo4j); **SharpHound** collects the data
- Reveals Kerberoastable SPNs, ACL escalations, sessions, local-admin rights; **DCSync** = pull all domain hashes
- **MITRE ATT&CK** = tactic / technique / procedure language; document with low-level diagrams + storyboards

TOOLS `BloodHound, SharpHound, MITRE ATT&CK`
EXAM TELL "shortest path to Domain Admin" -> **BloodHound**; **SharpHound** = collector; watch for next-step-in-chain questions.

3 · Confusables cram

The pairs and trios the exam blurs. The amber line is the distinction — learn that sentence.

OPPOSITE meanings — the #1 flag trap.

`nmap -sn`	`nmap -Pn`
Ping **sweep**: host discovery only, does **not** port-scan.	**Skip** discovery: assume host is up and **do** port-scan it.

Both find open TCP ports; differ in privilege + stealth.

`-sS (SYN)`	`-sT (connect)`
Half-open, sends RST after SYN-ACK. **Needs root**; stealthier.	Full 3-way handshake via OS socket. **No root**; more logged.

What each scan actually returns.

`-O` **OS** fingerprint only.	**`-sV`** **Service/version** only.	**`-A`** **Everything**: OS + version + default scripts + traceroute.

Two ways to find web content — use both.

`Web crawling` Follows **existing links** the app knows about (Burp/ZAP spider).	**`Directory enumeration`** Brute-forces **unlinked** paths from a wordlist (Gobuster/Wfuzz).

HTTP response codes in directory busting.

`403 Forbidden` Directory **exists** but is restricted — a finding, note it.	**`404 Not Found`** Resource does **not** exist — move on.

BloodHound family — collector vs analyzer.

`SharpHound` The **collector** agent that gathers AD data.	**`BloodHound`** The **graph GUI** that analyzes it and finds paths to DA.

Email enumeration — discover vs verify.

`theHarvester` **Discovers** addresses from many public/OSINT sources.	**`Hunter.io`** **Verifies** deliverability and reveals the naming format.

SMTP enumeration verbs.

`VRFY` **Verifies** whether one address exists.	**`EXPN`** **Expands** a mailing-list alias into its members.

Wireless — passive detect vs active capture.

`Kismet` **Passive** detector/sniffer — transmits nothing.	**`airodump-ng`** **Active** capture of frames/handshakes (Aircrack-ng suite).

Wireless discovery data sources.

`WiGLE.net` Crowdsourced **global AP database** — remote/passive recon.	**`InSSIDer`** **Live local** Wi-Fi analyzer (SSIDs, signal, channels).

Linux account files.

`/etc/passwd` **World-readable**; accounts + shells, **no passwords**.	**`/etc/shadow`** **Root-only**; the password **hashes**.

Windows credential stores.

`SAM` **Local** account hashes on a single host.	**`NTDS.dit`** **All domain** account hashes — lives on a domain controller.

SNMP community strings.

public
Default **read** community.

private
Default **read/write** community — higher value.

Web scanners — specific vs general.

WPScan
WordPress-specific: plugins, themes, core version + CVEs.

Nikto
General web-server scanner for common issues/versions.

SMB enumeration tools.

smbclient
Connect to / list shares on **one** host.

SMBMap
Shows each share's **permission** level (R/W/None).

CrackMapExec
Automates SMB enum + creds across a **subnet**.

Subdomain/dir/fuzz tools.

Amass
Subdomain enum (passive DNS + CT + brute).

Gobuster
Brute **dir / dns / vhost** modes.

Wfuzz
General **fuzzer** — dirs, params, headers.

4 · Quick reference

Ports & endpoints

PORT	SERVICE	WHY IT MATTERS
21	FTP	Cleartext creds; banner-grab for version
22	SSH	Version banner -> CVE; key-exchange enum
23	Telnet	Cleartext — creds sniffable
25	SMTP	VRFY/EXPN user enumeration
53	DNS (TCP+UDP)	AXFR zone transfer; TCP 53 for transfers
67/68	DHCP (UDP)	Internal host/IP intel
69	TFTP (UDP)	Config file grab, no auth
80	HTTP	Banner + header enum
110	POP3	Cleartext mail creds
139	SMB/NetBIOS	Legacy SMB; null-session enum
143	IMAP	Cleartext mail creds
161/162	SNMP (UDP)	Community strings; snmpwalk dumps device data
389	LDAP	AD structure; null-bind enum
443	HTTPS	TLS/cert enum; SAN subdomains
445	SMB	Primary share enum; EternalBlue on SMBv1
3306	MySQL	DB service enum
3389	RDP	NLA enforcement; lateral-move target
5985/5986	WinRM	Remote mgmt; Evil-WinRM target
169.254.169.254	Cloud metadata	IMDS — cloud access keys (not a port)

Nmap flags

FLAG	FUNCTION
-O	OS fingerprinting

FLAG	FUNCTION
-sV	Service/version detection
-A	Aggressive: OS + version + scripts + traceroute
-sS	TCP SYN (stealth/half-open) scan
-sT	TCP connect scan (no root)
-sU	UDP scan
-sn	Ping sweep — host discovery, no port scan
-Pn	Skip host discovery — assume host is up
-p-	Scan all 65535 ports
-sC	Run default NSE scripts
--script	Run a specific NSE script
-PS	TCP SYN ping (host discovery)
-PA	TCP ACK ping (bypasses stateful FW)
-PU	UDP ping
--osscan-guess	Force best-guess OS match
--version-intensity	Tune -sV depth (0-9)

HTTP response codes (directory enumeration)

CODE	MEANING	IMPLICATION
200	OK — resource exists and is served	Immediate target
301/302	Redirect	Exists; follows to another location
403	Forbidden — exists but access denied	Directory EXISTS — note it, try bypass
404	Not Found	Does not exist — move on
500	Server error	May signal a vulnerability

5 · Keyword → concept reference

Cover the right column and name the concept from the stem phrase.

KEYWORD / PHRASE	MAPS TO
-sn	Ping sweep (host discovery, no port scan)
-Pn	Skip discovery (assume up, do scan)
-PS / -PA	TCP SYN/ACK ping — bypass ICMP filtering
ARP discovery	Most reliable on a LAN (L2)
-O	OS fingerprinting (active)
p0f	Passive OS fingerprinting
TTL 128 / 64	Windows / Linux OS tell
-sV	Service version detection
banner grabbing	Read service announcement (nc/curl)
SNMP public/private	Read / read-write community strings
snmpwalk	Dump SNMP device data
SMBv1	EternalBlue / MS17-010 — critical
open|filtered	UDP ambiguous port state
null bind	Unauthenticated LDAP query
AXFR / dig axfr	DNS zone transfer — whole zone
SRV record	Hidden service discovery (LDAP/SIP/VoIP)

KEYWORD / PHRASE	MAPS TO
PTR record	Reverse DNS lookup
Amass	Subdomain enumeration
DNSdumpster	Visual DNS infra map
dangling CNAME	Subdomain takeover risk
403 Forbidden	Directory exists but restricted
404	Resource not found
Gobuster / Wfuzz	Directory brute forcing
CeWL	Custom wordlist from site content
directory listing	Misconfig exposing all files
AJAX spider	Crawl JS-heavy SPAs
Burp / ZAP spider	Web crawling / site map
crawling vs dir enum	Follow links vs brute paths
WafW00f	WAF detection/fingerprint
origin address	Real IP behind the WAF
CF-RAY	Cloudflare WAF indicator
DNS history / CT logs	Find origin IP
robots.txt Disallow	Map of sensitive paths (not a control)
sitemap.xml	Full URL inventory
WPScan	WordPress plugin/version enum
/wp-content/plugins/	WordPress plugin path
Port 445 / 139	SMB (modern / legacy)
IPC$	Null-session target
null session	Unauth SMB connect
SYSVOL	Domain share — GPP passwords
GPP passwords	Decryptable (public AES key)
SMBMap	Share permission levels (R/W/None)
CrackMapExec	Subnet-wide SMB/AD enum
enum4linux	Windows/Samba enum
/etc/passwd	World-readable accounts, no pw
/etc/shadow	Root-only password hashes
UID 0	Linux root
net localgroup administrators	Windows local admins
Get-LocalUser	List Windows local accounts
Backup Operators	High-value group (bypass file perms)
SMTP VRFY / EXPN	Verify address / expand list
theHarvester	OSINT email discovery
Hunter.io	Email verify + format
SUID	Runs as owner — Linux escalation
find / -perm -4000	Locate SUID files
Get-ObjectAcl	PowerView AD ACL enum
GenericAll	Full-control AD ACE — escalation
BloodHound	AD attack-path graph
SharpHound	BloodHound data collector

KEYWORD / PHRASE	MAPS TO
TruffleHog / GitLeaks	Secrets in Git history
169.254.169.254	Cloud metadata keys
SAM	Local Windows hashes
NTDS.dit	All domain hashes (on DC)
Mimikatz	Creds from LSASS
JWT manipulation	Forge if signing weak
Pacu	AWS IAM enum/exploit
Kismet	Passive wireless detection
airodump-ng	Active handshake capture
WiGLE.net	Global AP database
WPS / Pixie Dust	WPS PIN design flaw
WPA2-PSK	Offline dictionary after handshake
DCSync	Pull all domain hashes
MITRE ATT&CK	Adversary TTP framework
attack chain	Each step enables the next

6 · Recognition quiz (answer key included)

Weighted toward the confusables. Call it (tool + why), then check.

Q01

```
nmap -sn 10.0.0.0/24
```

What does this do — and what does it NOT do?

Ping sweep (host discovery only) P1

WHAT'S HAPPENING Discovers live hosts across the /24 without scanning any ports.
WHY The trap is `-Pn`, its opposite: `-Pn` **skips** discovery and **does** port-scan. `-sn` is discovery-only.

Q02

```
ICMP echo is filtered at the border, but you must find live hosts.
```

Which discovery method?

TCP SYN / ACK ping (-PS / -PA) P1

WHAT'S HAPPENING Send TCP SYN or ACK probes; any RST/SYN-ACK confirms the host is up.
WHY `-PA` (ACK) is especially good against stateful firewalls that drop unsolicited SYNs.

Q03

```
You need the OS but must send zero packets to the target.
```

Active or passive? Tool?

Passive OS fingerprinting (p0f) P1

WHAT'S HAPPENING p0f reads TTL and TCP window size from captured traffic — no probes.
WHY `nmap -O` would be active. TTL 128 vs 64 (Windows vs Linux) is the giveaway either way.

Q04

```
nmap -sU -p161 host returns no response.
```

Port state and likely service?

UDP open|filtered — SNMP P2

WHAT'S HAPPENING Silence on UDP is **open|filtered** — can't distinguish open from firewalled.
WHY Closed UDP returns ICMP Port Unreachable. 161 is SNMP; try `public`/`private` community strings next.

Q05

```
A directory buster returns 403 for /backup/.
```

What does 403 tell you?

403 = exists but restricted P3

WHAT'S HAPPENING The directory **exists**; access is denied — a finding worth a bypass attempt.
WHY The trap is 404 (does not exist). 403 means keep going, not move on.

Q06

```
The target is a React single-page app; the normal spider finds almost nothing.
```

What do you use?

AJAX spider (OWASP ZAP) P3

WHAT'S HAPPENING SPAs load content via JavaScript; only an AJAX spider/headless browser sees it.
WHY A standard crawler only follows <a href> links in static HTML and misses JS-rendered routes.

Q07

```
The site is behind Cloudflare (CF-RAY header). You want to bypass the WAF entirely.
```

What do you hunt for?

Origin IP address P3

WHAT'S HAPPENING Finding the server's real IP lets you connect directly, skipping all WAF filtering.
WHY Sources: DNS history, CT logs (crt.sh), non-proxied subdomains, SPF records, Shodan by certificate.

Q08

```
A DNS server accepts AXFR from any host.
```

Tool and command?

Zone transfer — dig axfr @ns domain P3

WHAT'S HAPPENING One request dumps the entire zone: all subdomains, IPs, MX, and hostnames.
WHY Highest-value DNS misconfig. If AXFR is blocked, fall back to brute forcing with Amass/dnsrecon.

Q09

```
You connect to IPC$ with no credentials and enumerate users.
```

What is this called?

Null session P4

WHAT'S HAPPENING An unauthenticated SMB connection to IPC$ that historically exposes users/groups/policy.
WHY Modern Windows restricts it, but legacy hosts and misconfigs still allow it. SMB = ports 445/139.

Q10

```
You can read /etc/passwd but not /etc/shadow.
```

What do you actually have?

Accounts only — no password hashes P4

WHAT'S HAPPENING passwd is world-readable and lists accounts/shells but contains **no** passwords.
WHY The hashes live in root-only /etc/shadow. Reading shadow would be the real prize (offline cracking).

Q11

```
You need every hash in the domain, not just one host.
```

Which store / technique?

NTDS.dit (or DCSync) P4

WHAT'S HAPPENING NTDS.dit on a domain controller holds all domain account hashes.
WHY The trap is SAM — that's only the **local** hashes on a single machine. DCSync pulls domain hashes remotely.

Q12

```
find / -perm -4000 lists a writable binary owned by root.
```

Why does this matter?

SUID privilege escalation P4

WHAT'S HAPPENING SUID binaries run as their owner (root) regardless of who executes them.
WHY A writable or abusable root-SUID file is a direct local privilege-escalation path.

Q13

```
TruffleHog flags an AWS key in a commit that was "deleted" from the current file.
```

Why is it still exposed?

Secrets persist in Git history P4

WHAT'S HAPPENING Removing a secret from the latest file leaves it intact in earlier commits.
WHY History is the real exposure surface. The key next feeds Pacu for AWS IAM enumeration.

Q14

```
You must passively detect wireless networks without transmitting anything.
```

Which tool?

Kismet P5

WHAT'S HAPPENING Kismet is a passive detector/sniffer in monitor mode — it transmits nothing.
WHY The trap is airodump-ng: it captures too, but as part of active auditing (with deauth via aireplay-ng).

Q15

```
A WordPress site — you want installed plugins and their CVEs.
```

Which tool?

WPScan P5

WHAT'S HAPPENING WPScan is WordPress-specific: enumerates plugins/themes/core and checks CVEs.
WHY Nikto is a general web-server scanner; WPScan is the CMS-specific answer here.

Q16

```
You have a foothold and want the shortest route to Domain Admin.
```

Which tool, and its collector?

BloodHound (collector: SharpHound) P6

WHAT'S HAPPENING BloodHound graphs AD relationships and computes the shortest path to DA.
WHY SharpHound gathers the data; BloodHound analyzes it. "next step in the chain" questions point here.